

Vulnerability Assessment Report

System: Metasploitable VM

Date: April 2025

Performed by: Izaan Shumaiz

Tool Used: Nmap (nmap -A -sV)

Purpose: To identify open ports, running services, and potential vulnerabilities for remediation.

1. Executive Summary

This vulnerability assessment was conducted on a virtual machine (VM) simulating a deliberately vulnerable system (Metasploitable). The goal was to identify and evaluate security weaknesses in exposed services. A total of 19 TCP ports were found open, with services exhibiting known vulnerabilities, deprecated versions, and misconfigurations. Critical security flaws such as backdoors, weak encryption, and outdated software were observed.

This vulnerability assessment was performed to identify security vulnerabilities present on the Metasploitable2 virtual machine. The goal was to simulate a basic penetration testing scenario and document the findings in a professional manner. The scope of the assessment was limited to the target IP address 192.168.56.103.

2. System Information

Target IP Address: 192.168.56.103

Operating System: Linux (identified by Nmap)

Hostname(s): metasploitable.localdomain, irc.Metasploitable.LAN (potential)

3. Detailed Findings

3.1. Port 21 – FTP (vsftpd 2.3.4)

- **Vulnerabilities:**
 - Known **backdoor vulnerability** in vsftpd 2.3.4 allows remote command execution.
 - **Anonymous login** is enabled, potentially exposing sensitive files.
- **Risk Level:**  Critical
- **Recommendation:** Upgrade vsftpd to a secure version. Disable anonymous access.

3.2. Port 22 – SSH (OpenSSH 4.7p1 Debian 8ubuntu1)

- **Vulnerabilities:**
 - Outdated version with known vulnerabilities.
 - Uses a **1024-bit DSA host key**, considered weak.
- **Risk Level:**  High
- **Recommendation:** Upgrade OpenSSH. Regenerate host keys using RSA (2048+ bits), ECDSA, or EdDSA.

3.3. Port 23 – Telnet (linux telnetd)

- **Vulnerabilities:**
 - Telnet **transmits data in plaintext**, making it vulnerable to eavesdropping.
- **Risk Level:**  Critical
- **Recommendation:** Disable Telnet; use SSH instead.

3.4. Port 25 – SMTP (Postfix smtpd)

- **Vulnerabilities:**
 - Supports **SSLv2**, an insecure protocol.
 - Uses **weak cipher suites**.
- **Risk Level:**  High
- **Recommendation:** Disable SSLv2 and enforce modern TLS (v1.2 or higher).

3.5. Port 53 – DNS (ISC BIND 9.4.2)

- **Vulnerabilities:**
 - Outdated version may contain **denial-of-service and cache poisoning vulnerabilities**.

- **Risk Level:**  High
- **Recommendation:** Upgrade BIND to the latest version.

3.6. Port 80 – HTTP (Apache httpd 2.2.8 (Ubuntu) DAV/2)

- **Vulnerabilities:**
 - Outdated Apache version vulnerable to exploits like directory traversal and DoS.
 - **DAV module** is enabled, which may expose the server to unintended file manipulations.
- **Risk Level:**  High
- **Recommendation:** Upgrade Apache. Disable DAV if not in use.

3.7. Ports 139 & 445 – SMB (Samba smbd 3.x–4.x)

- **Vulnerabilities:**
 - Version range suggests the presence of **EternalBlue-like vulnerabilities** depending on version.
- **Risk Level:**  Medium
- **Recommendation:** Identify specific Samba version. Apply latest patches and configure access restrictions.

3.8. Ports 512, 513, 514 – rsh, rlogin, rexec

- **Vulnerabilities:**
 - These services transmit data and credentials in **plaintext**.
 - Subject to **spoofing** and session hijacking.
- **Risk Level:**  Critical
- **Recommendation:** Disable these services and replace with SSH.

3.9. Port 1099 – Java RMI (GNU Classpath grmiregistry)

- **Vulnerabilities:**
 - RMI interfaces can be exploited if **deserialization vulnerabilities** exist.
- **Risk Level:**  Medium
- **Recommendation:** Limit RMI access and validate input. Investigate further based on version.

3.10. Port 1524 – Backdoor Shell (Metasploitable root shell)

- **Vulnerabilities:**
 - This is an **intentional root backdoor**, providing unrestricted access.

- **Risk Level:**  Critical
- **Recommendation:** Remove immediately. Audit system for other backdoors.

3.11. Port 2049 – NFS (Network File System v2-v4)

- **Vulnerabilities:**
 - Misconfigured NFS can allow unauthorized file access.
- **Risk Level:**  Medium
- **Recommendation:** Review /etc/exports configuration. Use IP restrictions and root_squash.

3.12. Port 2121 – FTP (ProFTPD 1.3.1)

- **Vulnerabilities:**
 - Outdated ProFTPD version may allow **unauthorized access or buffer overflows**.
- **Risk Level:**  High
- **Recommendation:** Upgrade to the latest ProFTPD release.

3.13. Port 3306 – MySQL (5.0.51a-3ubuntu5)

- **Vulnerabilities:**
 - Extremely outdated; vulnerable to multiple **authentication bypass and SQL injection** vulnerabilities.
- **Risk Level:**  Critical
- **Recommendation:** Upgrade MySQL. Enforce strong authentication and limit external access.

3.14. Port 5432 – PostgreSQL (v8.3.0 - 8.3.7)

- **Vulnerabilities:**
 - Vulnerable to **buffer overflows** and permission issues.
- **Risk Level:**  Critical
- **Recommendation:** Upgrade PostgreSQL. Enforce strong authentication and permissions.

3.15. Port 5900 – VNC (Protocol 3.3)

- **Vulnerabilities:**
 - May allow **unauthorized screen access** with weak or no password.
- **Risk Level:**  Medium
- **Recommendation:** Set a strong password. Tunnel VNC over SSH if needed.

3.16. Port 6667 – IRC (UnrealIRCd)

- **Vulnerabilities:**
 - Older UnrealIRCd versions were **trojanized** with backdoors.
- **Risk Level:**  High
- **Recommendation:** Confirm exact version and update. Block access unless required.

3.17. Port 8009 – AJP13 (Apache JServ Protocol)

- **Vulnerabilities:**
 - Misconfigurations can lead to **Tomcat Ghostcat vulnerability** (CVE-2020-1938).
- **Risk Level:**  Medium
- **Recommendation:** Restrict access to localhost or internal interfaces. Upgrade Tomcat.

3.18. Port 8180 – Apache Tomcat (v5.5)

- **Vulnerabilities:**
 - Severely outdated and subject to **multiple known exploits** (e.g., file upload bypass, default creds).
- **Risk Level:**  Critical
- **Recommendation:** Upgrade Tomcat to the latest version (v10+). Harden admin access.

3.19. Port 6000 – X11 (Access Denied)

- **Vulnerabilities:**
 - Remote X11 access can be hijacked if not properly secured.
- **Risk Level:**  Medium
- **Recommendation:** Disable X11 or restrict access using firewalls or xhost policies.

4. Findings Summary Table

Port	Service	Version	Risk Level	Key Vulnerabilities
21/tcp	FTP (vsftpd)	2.3.4	 Critical	Backdoor, Anonymous Login
22/tcp	SSH (OpenSSH)	4.7p1	 High	Outdated, Weak DSA key
23/tcp	Telnet	linux telnetd	 Critical	Cleartext transmission
25/tcp	SMTP (Postfix)	Unknown	 High	SSLv2 support
53/tcp	DNS (BIND)	9.4.2	 High	Outdated version
80/tcp	HTTP (Apache)	2.2.8	 High	Outdated, DAV enabled
139/445	SMB (Samba)	3.x–4.x	 Medium	Broad version range
512/513/514	R-Services	netkit-rshd, rlogind	 Critical	Cleartext r-commands
1099/tcp	Java RMI	grmiregistry	 Medium	Potential Java RMI issues
1524/tcp	Bind Shell	Metasploitable	 Critical	Root shell backdoor
2049/tcp	NFS	v2–v4	 Medium	Requires config review
2121/tcp	FTP (ProFTPD)	1.3.1	 High	Outdated
3306/tcp	MySQL	5.0.51a	 Critical	Highly outdated
5432/tcp	PostgreSQL	8.3.x	 Critical	Outdated
5900/tcp	VNC	v3.3	 Medium	Weak authentication risk
6667/tcp	IRC	UnrealIRCd	 High	Historical vulnerabilities
8009/tcp	AJP13	Apache JServ	 Medium	Possible misconfiguration
8180/tcp	Tomcat	5.5	 Critical	Outdated, multiple CVEs

5. Screenshots

The screenshot shows a terminal window titled "Metasploitable2 [Running] - Oracle VirtualBox". The terminal output includes the following text:

```

* Starting deferred execution scheduler atd [ OK
* Starting periodic command scheduler cron [ OK
* Starting Tomcat servlet engine tomcat5.5 [ OK
* Starting web server apache2 [ OK
* Running local boot scripts (/etc/rc.local)
nohup: appending output to 'nohup.out'
nohup: appending output to 'nohup.out' [ OK

Warning: Never expose this VM to an untrusted network!

Contact: msfdev[at]metasploit.com

Login with msfadmin/msfadmin to get started

metasploitable login: _

```

The terminal window has a menu bar with "File", "Machine", "View", "Input", "Devices", and "Help". The bottom of the window shows a taskbar with various application icons and the text "Right Ctrl".

```
lzaan@lzaan-VirtualBox:~$ ifconfig
enp0s3: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.56.102 netmask 255.255.255.0 broadcast 192.168.56.255
    inet6 fe80::63ef:39f8:76d4:7a84 prefixlen 64 scopeid 0x20<link>
    ether 08:00:27:7c:b2:75 txqueuelen 1000 (Ethernet)
    RX packets 47991 bytes 4494167 (4.4 MB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 67032 bytes 10463491 (10.4 MB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 2381 bytes 174740 (174.7 KB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 2381 bytes 174740 (174.7 KB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
```

```

Metasploitable2 [Running] - Oracle VirtualBox
File Machine View Input Devices Help

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.

msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:2b:01:88
          inet addr:192.168.56.103  Bcast:192.168.56.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe2b:188/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:66984 errors:0 dropped:0 overruns:0 frame:0
          TX packets:47906 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:10725625 (10.2 MB)  TX bytes:4438067 (4.2 MB)
          Base address:0xd020 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:114 errors:0 dropped:0 overruns:0 frame:0
          TX packets:114 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:29797 (29.0 KB)  TX bytes:29797 (29.0 KB)

msfadmin@metasploitable:~$

```

```
Izaan [Running] - Oracle VirtualBox
Activities Terminal 19:42 25 أبريل
Izaan@Izaan-VirtualBox: ~
Izaan@Izaan-VirtualBox:~$ nmap -A 192.168.56.103
Starting Nmap 7.80 ( https://nmap.org ) at 2025-04-25 19:40 +04
Nmap scan report for 192.168.56.103
Host is up (0.00085s latency).
Not shown: 977 closed ports
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ftp-syst:
|_STAT:
|_FTP server status:
|_  Connected to 192.168.56.102
|_  Logged in as ftp
|_  TYPE: ASCII
|_  No session bandwidth limit
|_  Session timeout in seconds is 300
|_  Control connection is plain text
|_  Data connections will be plain text
|_  vsFTPd 2.3.4 - secure, fast, stable
|_End of status
22/tcp    open  ssh            OpenSSH 4.7p1 Debian Bubuntu1 (protocol 2.0)
|_ssh-hostkey:
|_  1024 60:0f:cf:1e:1c:05:f7:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet         Linux telnetd
25/tcp    open  smtp           Postfix smtpd
|_smtp-command: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ET
RN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN,
|_ssl-date: 2025-04-25T15:41:29+00:00; 0s from scanner time.
|_sslv2:
|_SSLv2 supported
|_ciphers:
|_SSL2_DES_64_CBC_WITH_MD5
|_SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_SSL2_DES_192_EDE3_CBC_WITH_MD5
|_SSL2_RC2_128_CBC_WITH_MD5
```

```
Izaan [Running] - Oracle VirtualBox
Activities Terminal 19:45 25 أبريل
Izaan@Izaan-VirtualBox: ~
Izaan@Izaan-VirtualBox:~$ nmap -sV 192.168.56.103
Starting Nmap 7.80 ( https://nmap.org ) at 2025-04-25 19:44 +04
Nmap scan report for 192.168.56.103
Host is up (0.0010s latency).
Not shown: 977 closed ports
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            vsftpd 2.3.4
22/tcp    open  ssh            OpenSSH 4.7p1 Debian Bubuntu1 (protocol 2.0)
23/tcp    open  telnet         Linux telnetd
25/tcp    open  smtp           Postfix smtpd
53/tcp    open  domain         ISC BIND 9.4.2
80/tcp    open  http           Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind        2 (RPC #100000)
139/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec           netkit-rsh rshd
513/tcp   open  login          OpenBSD or Solaris rlogind
514/tcp   open  shell          Netkit rshd
1099/tcp  open  java-rmi       GNU Classpath grmiregistry
1524/tcp  open  bindshell      Metasploitable root shell
2049/tcp  open  nfs            2-4 (RPC #100003)
2121/tcp  open  ftp            ProFTPD 1.3.1
3306/tcp  open  mysql          MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql     PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc            VNC (protocol 3.3)
6000/tcp  open  X11            (access denied)
6667/tcp  open  irc            UnrealIRCd
8009/tcp  open  ajp13          Apache Jserv (Protocol v1.3)
8180/tcp  open  http           Apache Tomcat/Coyote JSP engine 1.1
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: U
nix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap
.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.03 seconds
Izaan@Izaan-VirtualBox:~$
```

6. Conclusion

The vulnerability assessment of the Metasploitable2 server revealed a significant number of critical and high-risk vulnerabilities. The presence of an intentional backdoor and numerous outdated and insecure services highlights the inherent risks associated with running vulnerable systems. Implementing the recommended remediation steps is crucial to improving the security posture of the system and preventing potential exploitation. This report serves as a starting point for hardening the Metasploitable2 environment.